

The Practitioner's Blueprint for Secure AI

By John M. Willis, Quantum Powered Security, Inc.



August 2025

Copyright and License

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc.

This manuscript is licensed under the Creative Commons Attribution 4.0 International License (CC BY 4.0). You are free to share and adapt this work for any purpose, including commercial use, provided appropriate attribution is given.

License: <https://creativecommons.org/licenses/by/4.0/>

Patent Notice

The concepts, architectures, and reference designs presented in this work are intended to encourage adoption, adaptation, and further innovation. Readers are encouraged to tailor PBSAI to their own environments, products, and services. Novel implementations, extensions, and improvements developed by others may be eligible for intellectual property protection under applicable patent laws.

The authors likewise reserve all rights to pursue patent protection for their own inventions, implementations, improvements, and future developments related to PBSAI. Certain aspects of this work are the subject of pending patent applications. Except as expressly stated by applicable law, no patent rights are granted or implied by this publication or its CC BY 4.0 license.

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

Volume 2: The Multi-Agent AI Defensive Cybersecurity Ecosystem

Domain K – Supply Chain & Lifecycle Security

Table of Contents

Domain K - Supply Chain & Lifecycle Security	4
K1. Procurement Policy Agent	4
Agent Blueprint [Informative]	4
Technical Implementation Details (K1) [Informative]	16
MCP-Native Protocol Specification (K1) [Normative]	18
K2. Authenticity Verification Agent	19
Agent Blueprint [Informative]	19
Technical Implementation Details (K2) [Informative]	32
MCP-Native Protocol Specification (K2) [Normative]	35
K3. SBOM Analysis Agent	36
Agent Blueprint [Informative]	36
Technical Implementation Details (K3) [Informative]	47
MCP-Native Protocol Specification (K3) [Normative]	49
K4. SECURE DISPOSAL AGENT	50
Agent Blueprint [Informative]	50
Technical Implementation Details (K4) [Informative]	63
MCP-Native Protocol Specification (K4) [Normative]	65

Domain K - Supply Chain & Lifecycle Security

K1. Procurement Policy Agent

Agent Blueprint [Informative]

Purpose: Enforce secure procurement requirements during sourcing and vendor selection; evaluate RFPs and bid packages against policy; emit a formal **ProcurementDecision** with traceable links to supplier risk scores.

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **E-Procurement Platform REST/GraphQL** (e.g., Coupa/Ariba/Oracle): RFP objects, workflow stage, required security clauses, vendor IDs, due dates.
- **Document Ingest (Object Storage/Email Gateway REST)**: bid package manifests and artifacts (PDF/DOCX/CSV/SBOM, attestations, questionnaires).

Model training / knowledge (what the LLM relies on):

- Style and rubric prompt pack for supply-chain controls (NIST 800-161; 800-53 SR/SA; organization procurement policies).
- RAG sources: procurement policy library, control checklist KB, supplier risk index (A9 SupplierRiskAgent records, BitSight/SecurityScorecard refs). Do not train on regulated evidence; use evidence_refs.
- Guardrails: read-only for storage; constrained write scopes to e-proc verdict fields; deny award/PO endpoints; allowlist of MIME types and schema validators for SBOM/attestation.

Decisions it makes (deterministic + model-assisted):

- **Artifact sufficiency:** SBOM presence and format (CycloneDX), SLSA level $\geq$ required, Sigstore/in-toto attestation valid, SOC 2 Type 2 date window, DPA present, VDP URL present.
- **Supplier risk gating:** combine external score + A9-derived score; evaluate threshold by category and data sensitivity.
- **Jurisdictional constraints:** data residency and export controls aligned with policy (e.g., region=US).
- **Verdict selection:** approve | conditional (with remediations/exceptions) | deny; generate rationale and traceable links to evidence and risk scores.

- **Classification:** default C2; elevate if documents include sensitive architectural details.

Routing / where outputs go:

- **ProcurementDecision** → Kafka/AMQP topic (authoritative decision event).
- **Sourcing status update** → e-procurement system REST field updates (verdict, exceptions required, blockers).
- **Exception workflow** → open risk remediation tasks and legal review tickets when conditional/deny.

Automation scope vs. manual/HITL:

- Fully automated: artifact presence/format checks; cryptographic validations (SLSA/intoto/Sigstore); external score retrieval; decision synthesis when below criticality threshold.
- **HITL required:** any **deny** decision; conditional approvals for CrownJewels or regulated data; exceptions to mandatory clauses (e.g., missing DPA, SLSA gap).
- Manual outside agent: contract redlines; commercial terms negotiation; vendor site visits.

Security Domain: Supply Chain & Lifecycle Security

Inputs (native protocols consumed) [Informative]

1. **E-Procurement Platform REST/GraphQL** — retrieve RFPs, vendor lists, stages, required security clauses.
2. **Document Ingest (Object Storage/Email Gateway REST)** — receive bid package manifests and artifacts.

Example: Consumed Protocol — E-Procurement Platform (RFP record)

[Informative]

Native payload

```
{
  "rfp_id": "RFP-2025-079",
  "title": "Cloud Email Gateway",
  "requestor": "Security",
  "stage": "BidsDue",
```

```

"security_requirements": {
  "sbom_required": true,
  "sbom_format": "CycloneDX",
  "slsa_level_min": 3,
  "sigstore_required": true,
  "soc2_type2_required": true,
  "dpa_required": true,
  "data_residency": ["US"],
  "vdp_url_required": true
},
"shortlist_vendors": ["VEND-00451", "VEND-00632"],
"due_date": "2025-09-01T00:00:00Z"
}

```

MCP-wrapped payload

```

{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-k1-rfp-1111-2222-3333-4444",
    "thread_id": "uuid-rfp-RFP-2025-079",
    "task_id": "uuid-aa11-bb22-cc33-dd44",
    "role": "ProcurementPolicyAgent",
    "intent": "govern",
    "policy_refs": ["ORG-SC-PROC-01", "NIST-800-161", "NIST-800-53 SR-3", "NIST-800-53 SA-12"],
    "constraints":
["no_award_without_security_clauses", "requires_sbom:cyclonedx", "requires_slsa_level:3", "region:US"],
    "decision_basis": {

```

```

    "evidence_refs": [
      "uri://eproc/rfps/RFP-2025-079",
      "uri://supplier-risk/vendors/VEND-00451/score/current",
      "uri://supplier-risk/vendors/VEND-00632/score/current"
    ],
    "confidence": 0.95,
    "explanation_ref": "uri://kb/procurement/security-requirements-checklist"
  },
  "provenance": {
    "producer_spiffe": "spiffe://enterprise/supplychain/procurement-policy-agent",
    "signing_kid": "kid-proc-01",
    "attestation_ref": "uri://slsa/attestations/procurement-policy@sha256:proc01"
  },
  "classification": "C2",
  "legal_hold": false
},
"native_payload": { ... }
}

```

Example: Consumed Protocol — Document Ingest (Bid package manifest)

[Informative]

Native payload

```

{
  "rfp_id": "RFP-2025-079",
  "vendor_id": "VEND-00451",
  "package": [
    {
      "name": "security_questionnaire.csv",
      "uri": "s3://proc/bids/VEND-00451/security_questionnaire.csv",
      "sha256": "f1a2..."
    }
  ]
}

```

```

    {"name": "soc2_type2_2025.pdf", "uri": "s3://proc/bids/VEND-00451/soc2_type2_2025.pdf", "sha256": "c0de..."},
    {"name": "sbom.cdx.json", "uri": "s3://proc/bids/VEND-00451/sbom.cdx.json", "sha256": "beef..."},
    {"name": "sigstore.attestation", "uri": "s3://proc/bids/VEND-00451/sigstore.intoto", "sha256": "1a2b..."}
  ],
  "submitted_at": "2025-08-20T17:30:00Z",
  "contact": "security@securecloud.example"
}

```

MCP-wrapped payload

```

{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-k1-bid-5555-6666-7777-8888",
    "thread_id": "uuid-bid-RFP-2025-079-VEND-00451",
    "task_id": "uuid-9911-8822-7733-6644",
    "role": "ProcurementPolicyAgent",
    "intent": "govern",
    "policy_refs": ["ORG-SC-PROC-01", "NIST-800-161", "SA-12", "SR-3"],
    "constraints":
["requires_sbom:cyclonedx", "requires_slsa_level:3", "no_award_without_security_clause
s"],
    "decision_basis": {
      "evidence_refs": [
        "uri://s3/proc/bids/VEND-00451/security_questionnaire.csv",
        "uri://s3/proc/bids/VEND-00451/soc2_type2_2025.pdf",
        "uri://s3/proc/bids/VEND-00451/sbom.cdx.json",
        "uri://s3/proc/bids/VEND-00451/sigstore.intoto",

```

```

    "uri://supplier-risk/vendors/VEND-00451/score/current"
  ],
  "confidence": 0.94,
  "explanation_ref": "uri://kb/procurement/checks#sbom-slsa-soc2-links"
},
"provenance": {
  "producer_spiffe": "spiffe://enterprise/supplychain/procurement-policy-agent",
  "signing_kid": "kid-proc-02",
  "attestation_ref": "uri://slsa/attestations/procurement-policy@sha256:proc02"
},
"classification": "C2",
"legal_hold": false
},
"native_payload": { ... }
}

```

Outputs (native) [Informative]

- **Kafka/AMQP ProcurementDecision** (approve | conditional | deny + reasons, evidence links).
- **REST update** back to sourcing system (verdict fields, exceptions required, blockers list).

MCP context (required) [Informative]

mission_id; role="ProcurementPolicyAgent"; intent="govern"; provenance (SPIFFE ID, signing KID, attestation); policy_refs (NIST 800-161; 800-53 SR/SA; org policy IDs)

MCP context (optional) [Informative]

constraints (e.g.,
 "no_award_without_security_clauses", "requires_sbom:cyclonedx", "requires_slsa_level: 3", "region:US"); classification (usually C2); decision_basis (include supplier risk links); legal_hold

Enforcement note [Informative]

PEPs in sourcing must **block award** if **no valid ProcurementDecision** (signed provenance) or if **constraints** are unmet (e.g., requires_sbom, requires_slsa_level, region).

NIST SP 800-160v2 linkage [Informative]

Resilience through trusted sourcing and verifiable requirements; aligns with secure lifecycle and dependency risk containment.

Automation feasibility [Informative]

High (artifact and attestation checks, score retrieval, policy gating automated; exceptions HITL).

Output Contracts (merged) [Informative]

OC-1: ProcurementDecision (Event) [Informative]

- **Producer(s):** K1
- **Topic/Path:** sec.procurement.decision (Kafka/AMQP)
- **Schema/Format:** ProcurementDecision@1.0 (verdict, reasons[], evidence_refs[], supplier_risk_refs[], constraints_applied[], signature)
- **Classification:** C2
- **Delivery:** at-least-once
- **Ordering:** per-rfp_id
- **Idempotency-Key:** sha256(rfp_id, vendor_id, decision_version)
- **Ack/Nack:** broker ACK; NACK → retry
- **Timeouts/Retry:** ack<=10s; exp-backoff<=6x
- **Side-Effects:** write decision summary to sourcing comment thread; link case if conditional/deny
- **HITL Token:** required for deny on business-critical category or exception to mandatory clause
- **Observability:** trace_id, mission_id, policy_refs, supplier_risk_refs, decision_basis.*, classification_label, provenance.attestation
- **Retention/TTL:** 7 years

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=ProcurementDecision@1.0 | json_schema_uri=uri://schema/procurement-decision-1.0.json | sha256= | producers=K1 | consumers=EProc-PEP-01, SupplierRisk-Index-01 | accepts=1.0–1.x

Conformance: Normative.

OC-2: SourcingSystemUpdate (Verdict Sync) [Informative]

- **Producer(s):** K1
- **Endpoint:** PUT /rfps/{rfp_id}/vendors/{vendor_id}/decision (e-proc system)
- **Schema/Format:** VerdictSync@1.0 (verdict, exceptions_required, blockers[], rationale_uri, signature)
- **Classification:** C2
- **Delivery:** exactly-once per rfp_id+vendor_id
- **Ordering:** per-rfp_id
- **Idempotency-Key:** sha256(rfp_id, vendor_id, decision_version)
- **Ack/Nack:** 2xx ACK; 4xx/5xx NACK → retry/backoff and raise ticket
- **Side-Effects:** status field mutation in e-proc; attach rationale link
- **HITL Token:** required when status would change to Denied for business-critical categories
- **Observability:** trace_id, mission_id, policy_refs, decision_rationale_url, provenance.attestation
- **Retention/TTL:** system of record retains per procurement policy

Schema Capsule (OC-2) [Normative]

Requirement Level: Conditionally Required

Condition: When an e-procurement integration is present or the system acts as system of record for award gating

schema_id=VerdictSync@1.0 | json_schema_uri=uri://schema/verdict-sync-1.0.json | sha256= | producers=K1 | consumers=EProc-01 | accepts=1.0–1.x

Conformance: Normative when condition is met.

OC-3: PolicyDispute (Explainability and Contestability) [Informative, optional]

- **Producer(s):** K1, Legal-Portal-01, Compliance-Portal-01
- **Topic/Path:** sec.procurement.contestation
- **Schema/Format:** PolicyDispute@1.0
- **Classification:** C2+
- **Delivery/Ordering:** at-least-once; per-rfp_id
- **Idempotency-Key:** sha256(rfp_id, vendor_id, dispute_id)
- **Ack/Nack:** case_id in <=30s else retry/backoff
- **Side-Effects:** pause award; notify counsel/compliance
- **HITL Token:** required when dispute severity >= high
- **Observability:** trace_id, mission_id, policy_refs, decision_rationale_url
- **Retention/TTL:** 7 years

Schema Capsule (OC-3) [Normative]

Requirement Level: Optional

Condition: When contestability is enabled

schema_id=PolicyDispute@1.0 | json_schema_uri=uri://schema/policy-dispute-1.0.json

Conformance: Normative if implemented or claimed.

OC-4: IRPolicyViolationEvent (Incident Response Integration) [Informative, optional]

- **Producer(s):** K1
- **Topic/Path:** sec.procurement.incident
- **Schema/Format:** IRPolicyViolationEvent@1.0 (e.g., fraud, forged attestations)
- **Classification:** C2
- **Delivery/Ordering:** at-least-once; per-incident_id
- **Idempotency-Key:** sha256(incident_id, rfp_id, vendor_id)
- **Ack/Nack:** SIEM/CaseID in <=30s; retry/backoff
- **Side-Effects:** open SOAR case; link artifacts and attestation failures

Schema Capsule (OC-4) [Normative]

Requirement Level: Optional

Condition: When IR/SIEM integration is present

schema_id=IRPolicyViolationEvent@1.0 | json_schema_uri=uri://schema/ir-policy-violation-1.0.json

Conformance: Normative if implemented or claimed.

OC-5: ExceptionRequest (Risk/Clause Exception Workflow) [Informative, optional]

- **Producer(s):** K1 (on conditional), Requestor-Portal-01
- **Topic/Path:** sec.procurement.exception_request
- **Schema/Format:** ExceptionRequest@1.0 (clause_id, justification, compensating_controls, expiry)
- **Classification:** C2
- **Delivery/Ordering:** at-least-once; per-rfp_id
- **Idempotency-Key:** sha256(rfp_id, vendor_id, exception_key)
- **Ack/Nack:** case_id created; retry/backoff
- **Side-Effects:** blocks award until approved; creates review tasks (Security/Legal)

Schema Capsule (OC-5) [Normative]

Requirement Level: Conditionally Required

Condition: When exception handling is enabled or any conditional approvals are issued

schema_id=ExceptionRequest@1.0 | json_schema_uri=uri://schema/exception-request-1.0.json

Conformance: Normative when condition is met.

OC-6: FeedbackIngestionEvent (Stakeholder Feedback Loop) [Informative, optional]

- **Producer(s):** Buyer/Requester portals; K1 (aggregation)
- **Topic/Path:** sec.procurement.feedback
- **Schema/Format:** FeedbackIngestionEvent@1.0
- **Classification:** C1
- **Delivery/Ordering:** at-least-once; per-review_id

- **Idempotency-Key:** sha256(review_id, rfp_id, vendor_id)
- **Ack/Nack:** feedback_id assigned; retry/backoff
- **Side-Effects:** feeds governance-reviewed learning queue (prompt/rubric updates)

Schema Capsule (OC-6) [Normative]

Requirement Level: Optional

Condition: When stakeholder feedback workflow is enabled

schema_id=FeedbackIngestionEvent@1.0 | json_schema_uri=uri://schema/feedback-ingestion-1.0.json

Conformance: Normative if implemented or claimed.

State machine (concise) [Informative]

states = { idle, collecting_artifacts, validating_artifacts, scoring_supplier, adjudicating, publishing_decision, syncing_sourcing, contestation_workflow, failed, closed }

transition(idle -> collecting_artifacts) when RFP enters BidsDue or bid manifest arrives

transition(collecting_artifacts -> validating_artifacts) when package complete

transition(validating_artifacts -> scoring_supplier) when SBOM/SLSA/attestations verified

transition(scoring_supplier -> adjudicating) when risk data fetched

transition(adjudicating -> publishing_decision) when verdict computed

transition(publishing_decision -> syncing_sourcing) when OC-1 ACK received

transition(adjudicating -> contestation_workflow) when dispute opened or auto-escalation triggers

transition(* -> failed) on validation error or timeout

timeout(validating_artifacts, 5m) -> failed; retry <= 3 with exp backoff

idempotency_key = sha256(rfp_id, vendor_id, decision_version)

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 ProcurementDecision	Required	Always	Award gating and auditability

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-2 SourcingSystemUpdate	Conditionally Required	E-proc integration present / acts as system of record	Workflow synchronization
OC-3 PolicyDispute	Optional	Contestability enabled	Governance workflow
OC-4 IRPolicyViolationEvent	Optional	IR/SIEM integration present	Incident response
OC-5 ExceptionRequest	Conditionally Required	Conditional approvals or exception handling enabled	Risk management and approvals
OC-6 FeedbackIngestionEvent	Optional	Stakeholder feedback workflow	Continuous improvement

Requirement Level Definitions:

- **Required:** Must be implemented for conformant deployment
- **Conditionally Required:** Must be implemented when trigger condition is met
- **Optional:** May be implemented for enhanced functionality

Policies and HITL gates [Informative]

- policy_refs: NIST 800-161; NIST 800-53 SR-X/SA-X; org procurement policies.
- **HITL required:** any deny; conditional approvals for CrownJewels/regulated data; exceptions on mandatory clauses (DPA, SLSA level).
- **Automatic HITL escalation triggers:** model_confidence < theta_low; supplier_risk_breach = true; artifact_integrity_failure = true; stakeholder_disagreement_score >= 0.5.
- **Manual outside agent:** contract/legal redlines; bespoke compensating controls negotiation.

SLOs and KPIs [Informative]

- DecisionPublishAck_p95 <= 10 s

- SourcingSyncAck_p95 <= 30 s
- FalseApprovalRate_30d <= 1 percent
- DenyAppealResolution_p95 <= 5 business days

Outputs index [Informative]

[OC-1 ProcurementDecision], [OC-2 SourcingSystemUpdate], [OC-3 PolicyDispute], [OC-4 IRPolicyViolationEvent], [OC-5 ExceptionRequest], [OC-6 FeedbackIngestionEvent]

Technical Implementation Details (K1) [Informative]

Model and training profile [Informative]

model_id=procurement-governance-text; temperature=0.1; max_tokens_out=900
 prompt_pack_id=proc-policy-v1 (rubrics for SBOM/SLSA/SOC2/DPA/VDP checks; jurisdiction rules)
 RAG: sources={procurement policies, control checklist KB, supplier risk index};
 max_docs=8; min_similarity=0.78; citations required
 fine_tuning/adapters: none initially; eval gates on hallucination and rubric compliance
 guardrails: MIME/type allowlist; schema validation for CycloneDX; signature/attestation verifiers only

Memory and state [Informative]

working_memory.max_tokens=4k; eviction=recency_then_importance
 episodic_memory: per mission_id decision journal (inputs, checks, verdicts), ttl=365d
 semantic_memory: namespaces=["proc-policies","supplier-risk","artifact-schemas"];
 embeddings=text-embedding-sec-v1; k=8
 durable_state_store: event-sourced decision log; snapshot at each verdict version
 consistency: at-least-once (OC-1); exactly-once (OC-2 per rfp_id+vendor_id)
 idempotency: per Output Contracts

Decision and routing logic [Informative]

Define normalized supplier risk: $\text{supplier_risk_norm} = \min(\max((\text{score} - \text{min_score}) / (\text{max_score} - \text{min_score}), 0), 1)$

Missing artifacts count: missing_artifacts in {0,1,2,...}

SLSA gap: $\text{slsa_gap} = \max(0, \text{slsa_required} - \text{slsa_provided})$

$\text{procurement_risk_score} = 0.35(1 - \text{supplier_risk_norm}) + 0.25\text{indicator}(\text{missing_artifacts} > 0) + 0.20\text{indicator}(\text{artifact_integrity_failure}) + 0.10\text{indicator}(\text{data_residency_mismatch}) + 0.10 * \min(\text{slsa_gap} / 2, 1)^{**}$

Verdict thresholds (example policy):

- approve if `procurement_risk_score < 0.25` and all mandatory clauses satisfied
- conditional if `0.25 <= procurement_risk_score < 0.55` or minor clause gaps with compensating controls
- deny if `procurement_risk_score >= 0.55` or any critical clause missing (e.g., no DPA, forged attestation)

routing: publish OC-1 → on ACK sync OC-2 → if conditional, emit OC-5 and pause award; on forged/invalid artifacts, emit OC-4; disputes route to OC-3.

Model Risk Management [Informative]

`continuous_validation`: daily; `eval_suite`=[goldens for artifact sets, adversarial forged SLSA/attestation, jailbreak prompts]

`thresholds`: `eval_pass_rate >= 99.5` percent → `auto_HITL` if below

`red_team_cycle`: monthly (fake SBOMs, manipulated scores)

`rollback_policy`: `eval_drop >= 1.5` percentage points for 48 h → revert `model_id`; notify owners

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

`decision_rationale_template`: who, what, why; `evidence_refs`; `supplier_risk_refs`; hashes; `constraints_applied`

UI/API: expose `classification_label`, `provenance.attestation`, `decision_rationale_url`

`audit_log_format`: JSONL stable fields; retention per classification/legal_hold

Incident Response Integration [Informative]

Emit OC-4 on suspected fraud or attestation forgery; SOAR opens case and quarantines bid artifacts.

Change Impact Assessment [Informative]

When policies change (e.g., SLSA level), run retro-validation across open RFPs and notify buyers (out of scope for K1 outputs; handled by governance ops).

Stakeholder Feedback Loop [Informative]

Collect buyer/security feedback via OC-6; update `prompt_pack` after governance review; never auto-train on regulated artifacts.

Data Sovereignty and Legal Hold [Informative]

Enforce region constraints at ingress; `legal_hold=true` freezes decision purge; extend TTL.

Interfaces (links only) [Informative]

Consumes: E-Procurement REST/GraphQL; Document Ingest REST

Produces: OC-1, OC-2, OC-3, OC-4, OC-5, OC-6

Safety and abuse prevention [Informative]

kill_switch on signature mismatch or attestation anomalies; sandbox parsing; cost/QPS caps by mission_id

Testing and validation [Informative]

contract tests for OC-1/OC-2; offline replay of historical bids; red-team forged attestations; drift checks and rollback

Deployment and lifecycle [Informative]

HPA on queue depth; canary for decision rules; SBOM + in-toto/SLSA attestations; sign all outputs

References / Standards [Informative]

NIST SP 800-161; NIST SP 800-53 Rev. 5 (SR/SA); NIST SP 800-160 Vol. 2; NIST CSF 2.0; ISO/IEC 27036; SLSA; in-toto; Sigstore; CycloneDX; MITRE ATT&CK/D3FEND (procurement-relevant patterns)

MCP-Native Protocol Specification (K1) [Normative]

- **Native Protocol(s) Consumed:** E-Procurement Platform REST/GraphQL; Document Ingest (Object Storage/Email Gateway REST)
- **Native Protocol(s) Produced:** ProcurementDecision event (Kafka/AMQP); Sourcing verdict REST updates
- **MCP Context Fields:**
 - **Required:** mission_id; role="ProcurementPolicyAgent"; intent="govern"; provenance (SPIFFE ID, signing KID, attestation); policy_refs
 - **Optional:** constraints; classification; decision_basis (must include supplier risk links); legal_hold
- **Enforcement Note:** Award/PO issuance MUST verify a signed ProcurementDecision and applicable constraints; PEPs MUST block award on failure.

- **Versioning and compatibility; producers/consumers registry:** authoritative here; see Schema Capsules for acceptance ranges/EOL dates.
- **Example payloads:** native and MCP-wrapped examples above (authoritative).
- **Transparency hooks:** `classification_label`, `provenance.attestation`, `decision_rationale_url` exposed to downstream UIs/APIs.

Conformance: This section is **[Normative]** and, together with each **Schema Capsule**, defines testable requirements.

K2. Authenticity Verification Agent

Agent Blueprint [Informative]

Purpose: Validate the authenticity of hardware and software components by verifying certificate chains, signatures, transparency/attestation records, and strong hashes; emit an **AuthenticityReport**.

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **X.509 component certificates** (PEM/DER chains): leaf, intermediates, root hints; CRL and OCSP endpoints; EKU/OID constraints; SPKI hashes.
- **Hash manifests** (SHA-256 or SHA-512): per-artifact checksums; optional publisher signatures.
- **Sigstore / in-toto attestations:** Fulcio-issued certs, Rekor transparency log entries, DSSE envelopes with SLSA provenance.

Model training / knowledge (what the LLM relies on):

- Prompt pack with cryptographic policy rubrics (NIST 800-161; 800-53 SA-12, SR-3, SR-6, SI-7; SLSA levels; acceptable algorithms; trust anchor rules).
- RAG sources: enterprise trust store (roots, EKUs, CT policy), revocation policy, approved builders list, transparency-log metadata, validator error catalog. Do not train on vendor-confidential evidence; use `evidence_refs`.
- Guardrails: read-only fetch of artifacts; deterministic verifiers only; deny writes to deployment endpoints; allowlist of MIME types (pem, der, json, cdx, asc).

Decisions it makes (deterministic + model-assisted):

- **Chain validation:** builds path to approved trust anchors; checks EKU and name constraints; verifies time validity with `clock_skew_max`; enforces algorithm policy.

- **Revocation status:** CRL and/or OCSP checks according to policy (require_revocation_check).
- **Hash integrity:** recomputes hash and compares to manifest; optionally verifies publisher signature.
- **Transparency/attestation:** verifies Rekor inclusion proof and Fulcio leaf; checks DSSE signature and SLSA predicate; enforces require_transparency_log.
- **Provenance policy:** validates builder.id against allowlist and minimum SLSA level.
- **Verdict selection:** authentic | authentic_with_warnings | not_authentic; attaches reasons, error codes, and evidence_refs; sets classification (C2 default, up to C3 when vendor cert data is sensitive).

Routing / where outputs go:

- **AuthenticityReport** → REST/gRPC to requesting service or pipeline gate.
- **AuthenticityResult** → Kafka/AMQP for SBOM Analysis Agent and Supplier Risk Agent.
- **IR event** → SOC queue on suspected forgery or tampering.

Automation scope vs. manual/HITL:

- Fully automated: all cryptographic checks, Rekor lookup, DSSE and hash verification, builder allowlist checks.
- **HITL required:** ambiguous revocation (OCSP unknown and CRL unreachable with require_revocation_check=true), expired but within emergency grace window, transparency log outage when require_transparency_log=true, conflicting chain paths.
- Manual outside agent: vendor outreach for reissue, legal review on licensing or export-control flags.

Security Domain: Supply Chain & Lifecycle Security

Inputs (native protocols consumed) [Informative]

1. **X.509 Component Certificates** — device or code-signing cert chains in PEM/DER (with CRL/OCSP pointers).
2. **Hash Manifests** — strong digest manifests for artifacts (SHA-256 or SHA-512).

3. **Sigstore / in-toto Attestations** — Fulcio certs and Rekor entries, DSSE with SLSA provenance.

Example: Consumed Protocol — X.509 Component Certificates [Informative]

Native payload (summarized JSON)

```
{
  "leaf": {
    "subject": "CN=SecureCloud Update Signing",
    "issuer": "CN=SecureCloud Intermediate CA",
    "serial": "5E:91:AF:02:77:8B",
    "not_before": "2025-07-01T00:00:00Z",
    "not_after": "2026-07-01T00:00:00Z",
    "ski": "90C7...A1",
    "aki": "1F22...B9",
    "key_usage": ["digitalSignature", "codeSigning"],
    "spki_sha256": "a7c1c51d...f9e2"
  },
  "intermediate": {
    "subject": "CN=SecureCloud Intermediate CA",
    "issuer": "CN=SecureCloud Root CA",
    "serial": "77:12:AA:EF:19",
    "crl_dp": "http://pki.securecloud.example/crl/intermediate.crl",
    "aia": "http://pki.securecloud.example/ca/intermediate.cer"
  },
  "root_hint": "CN=SecureCloud Root CA"
}
```

MCP-wrapped payload

```
{
```

```

"mcp_context": {
  "mcp_version": "0.9",
  "mission_id": "uuid-k2-x509-1111-2222-3333-4444",
  "thread_id": "uuid-x509-securecloud-chain-2025-08-20",
  "task_id": "uuid-aa11-bb22-cc33-dd44",
  "role": "AuthenticityVerificationAgent",
  "intent": "verify",
  "policy_refs": ["NIST-800-161", "NIST-800-53 SA-12", "NIST-800-53 SR-6"],
  "constraints": ["region:US", "require_revocation_check:true", "clock_skew_max:300s"],
  "decision_basis": {
    "evidence_refs": [
      "uri://pki/certs/securecloud/update-signing/leaf.pem",
      "uri://pki/certs/securecloud/intermediate.pem",
      "uri://truststore/root/securecloud-root"
    ],
    "confidence": 0.98,
    "explanation_ref": "uri://kb/authenticity/x509-path-validation#code-signing"
  },
  "provenance": {
    "producer_spiffe": "spiffe://enterprise/supplychain/authenticity-agent",
    "signing_kid": "kid-x509-01",
    "attestation_ref": "uri://slsa/attestations/authenticity@sha256:x50901"
  },
  "classification": "C2",
  "legal_hold": false
},
"native_payload": { ... }

```

```
}
```

Example: Consumed Protocol — Hash Manifests [Informative]

Native payload

```
{
```

```
  "artifact_uri": "https://downloads.securecloud.example/agent/agent-4.7.2-linux-x64.tar.gz",
```

```
  "hashes": {
```

```
    "sha256":
```

```
    "f21f4a50c5a5b9e0d5a1f0f7a5a2b8f0c4e7b2e3d6e1a9c0f2e8b1d7c4a9012b",
```

```
    "sha512": "7f0c...b9a1"
```

```
  },
```

```
  "published_at": "2025-08-18T06:00:00Z",
```

```
  "publisher_sig": "optional.asc"
```

```
}
```

MCP-wrapped payload

```
{
```

```
  "mcp_context": {
```

```
    "mcp_version": "0.9",
```

```
    "mission_id": "uuid-k2-hash-5555-6666-7777-8888",
```

```
    "thread_id": "uuid-hash-agent-4.7.2-linux-x64",
```

```
    "task_id": "uuid-9911-8822-7733-6644",
```

```
    "role": "AuthenticityVerificationAgent",
```

```
    "intent": "verify",
```

```
    "policy_refs": ["NIST-800-161", "NIST-800-53 SI-7"],
```

```
    "constraints": ["region:US", "require_transparency_log:true"],
```

```
    "decision_basis": {
```

```
      "evidence_refs": [
```

```
        "https://downloads.securecloud.example/agent/agent-4.7.2-linux-x64.tar.gz",
```

```

    "https://downloads.securecloud.example/agent/agent-4.7.2-linux-
x64.tar.gz.sha256"
  ],
  "confidence": 0.97,
  "explanation_ref": "uri://kb/authenticity/hash-verification#sha256"
},
"provenance": {
  "producer_spiffe": "spiffe://enterprise/supplychain/authenticity-agent",
  "signing_kid": "kid-hash-02",
  "attestation_ref": "uri://slsa/attestations/authenticity@sha256:hash02"
},
"classification": "C1",
"legal_hold": false
},
"native_payload": { ... }
}

```

Example: Consumed Protocol — Sigstore / in-toto Attestations [Informative]

Native payload

```

{
  "artifact_digest": "sha256:9c3c...a7f2",
  "signature": "MEUCIQD1...==",
  "certificate_pem": "-----BEGIN CERTIFICATE-----\nMIIB...snip...\n-----END
CERTIFICATE-----",
  "rekor": {"logIndex": 12044567, "integratedTime": 1765862400, "uuid": "25f1c2e9-
9b41-4f4c-9f5d-0b3d3a3e7e3d"},
  "intoto_statement": {
    "predicateType": "https://slsa.dev/provenance/v1",
    "builder.id": "https://github.com/actions/runner",

```

```

    "buildType": "slsa3",
    "subjects": [{"name": "agent-4.7.2-linux-x64.tar.gz", "digest": {"sha256": "9c3c...a7f2"}}]
  }
}
MCP-wrapped payload
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-k2-sigstore-9999-aaaa-bbbb-cccc",
    "thread_id": "uuid-cosign-agent-4.7.2-linux-x64",
    "task_id": "uuid-1122-3344-5566-7788",
    "role": "AuthenticityVerificationAgent",
    "intent": "verify",
    "policy_refs": ["SLSA-3", "NIST-800-161", "NIST-800-53 SA-12"],
    "constraints": ["region:US", "require_transparency_log:true"],
    "decision_basis": {
      "evidence_refs": [
        "uri://rekor/entries/25f1c2e9-9b41-4f4c-9f5d-0b3d3a3e7e3d",
        "uri://sigstore/certs/MIIB...snip",
        "uri://intoto/statements/agent-4.7.2-linux-x64"
      ],
      "confidence": 0.99,
      "explanation_ref": "uri://kb/authenticity/sigstore-integration#fulcio-rekor-slsa"
    },
    "provenance": {
      "producer_spiffe": "spiffe://enterprise/supplychain/authenticity-agent",
      "signing_kid": "kid-sigstore-03",

```

```

    "attestation_ref": "uri://slsa/attestations/authenticity@sha256:sig03"
  },
  "classification": "C2",
  "legal_hold": false
},
"native_payload": { ... }
}

```

Outputs (native) [Informative]

- **REST/gRPC AuthenticityReport:** verdict, reasons, evidence refs, chain summary, revocation status, transparency proofs, SLSA level.
- **Kafka/AMQP AuthenticityResult:** normalized event for downstream agents (SBOM Analysis, Supplier Risk).

MCP context (required) [Informative]

mission_id; role="AuthenticityVerificationAgent"; intent="verify"; provenance (SPIFFE ID, signing KID, attestation); policy_refs (NIST 800-161; 800-53 SA-12/SR-3/SR-6; SLSA)

MCP context (optional) [Informative]

constraints (e.g., "region:US", "require_revocation_check:true", "require_transparency_log:true", "clock_skew_max:300s"); classification (C2 default); decision_basis (evidence refs, confidence, explanation_ref); legal_hold

Enforcement note [Informative]

Deployment and ingestion gateways **MUST** require a signed **AuthenticityReport** for each artifact. If verdict != authentic (or required constraints unmet), the action **MUST** be blocked or quarantined.

NIST SP 800-160v2 linkage [Informative]

Resilience by **assured sourcing** and **integrity validation** of dependencies; supports detect and withstand goals.

Automation feasibility [Informative]

High (cryptographic verification and policy checks are deterministic and automatable).

Output Contracts (merged) [Informative]

OC-1: AuthenticityReport (REST/gRPC) [Informative]

- **Producer(s):** K2
- **Endpoint/Path:** POST /auth/v1/report or gRPC Authenticity.Verify
- **Schema/Format:** AuthenticityReport@1.0 (verdict, reasons[], error_codes[], evidence_refs[], chain_summary, revocation_status, transparency_proofs[], slsa_level, constraints_applied[], signature, provenance)
- **Classification:** C2 (C3 if vendor PKI secrets present)
- **Delivery:** exactly-once per artifact_digest + verification_profile
- **Ordering:** per artifact_digest
- **Idempotency-Key:** sha256(artifact_digest, verification_profile, policy_version)
- **Ack/Nack:** 2xx or gRPC OK is ACK; 4xx/5xx NACK → retry/backoff and open ticket
- **Timeouts/Retry:** ack≤5s; exp-backoff≤5x
- **Side-Effects:** append report to authenticity journal; link to build or intake record
- **HITL Token:** required if revocation_status = unknown with require_revocation_check=true
- **Observability:** trace_id, mission_id, policy_refs, decision_basis.*, classification_label, provenance.attestation
- **Retention/TTL:** 7 years

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=AuthenticityReport@1.0 | json_schema_uri=uri://schema/authenticity-report-1.0.json | sha256= | producers=K2 | consumers=Deploy-PEP-01, Intake-PEP-01 | accepts=1.0–1.x

Conformance: Normative.

OC-2: AuthenticityResultEvent (Kafka/AMQP) [Informative]

- **Producer(s):** K2

- **Topic/Path:** sec.supplychain.authenticity.result
- **Schema/Format:** AuthenticityResult@1.0 (artifact_digest, verdict, reasons[], evidence_refs[], slsa_level, transparency_ok, revocation_ok, report_uri)
- **Classification:** C2
- **Delivery:** at-least-once
- **Ordering:** per artifact_digest
- **Idempotency-Key:** sha256(artifact_digest, report_id)
- **Ack/Nack:** broker ACK; NACK → retry/backoff
- **Side-Effects:** notify SBOM Analysis Agent and Supplier Risk Agent
- **HITL Token:** none (event only)
- **Observability:** trace_id, mission_id, policy_refs, provenance.attestation
- **Retention/TTL:** 1 year

Schema Capsule (OC-2) [Normative]

Requirement Level: Conditionally Required

Condition: When downstream consumers (SBOM Analysis, Supplier Risk) are integrated

schema_id=AuthenticityResult@1.0 | json_schema_uri=uri://schema/authenticity-result-1.0.json | sha256= | producers=K2 | consumers=A8-SBOM, A9-SupplierRisk | accepts=1.0–1.x

Conformance: Normative when condition is met.

OC-3: PolicyDispute (Explainability and Contestability) [Informative, optional]

- **Producer(s):** K2, Legal-Portal-01
- **Topic/Path:** sec.supplychain.contestation
- **Schema/Format:** PolicyDispute@1.0
- **Classification:** C2+
- **Delivery/Ordering:** at-least-once; per artifact_digest
- **Idempotency-Key:** sha256(artifact_digest, dispute_id)
- **Ack/Nack:** case_id in <=30s else retry/backoff
- **Side-Effects:** pause deployment; open appeal workflow

Schema Capsule (OC-3) [Normative]

Requirement Level: Optional

Condition: When contestability is enabled

schema_id=PolicyDispute@1.0 | json_schema_uri=uri://schema/policy-dispute-1.0.json

Conformance: Normative if implemented or claimed.

OC-4: IRPolicyViolationEvent (Suspected Forgery/Tamper) [Informative, optional]

- **Producer(s):** K2
- **Topic/Path:** sec.supplychain.incident
- **Schema/Format:** IRPolicyViolationEvent@1.0 (indicator, details, artifact_digest, vendor_id?)
- **Classification:** C2
- **Delivery/Ordering:** at-least-once; per-incident_id
- **Idempotency-Key:** sha256(incident_id, artifact_digest)
- **Ack/Nack:** SIEM/CaseID <=30s; retry/backoff
- **Side-Effects:** SOAR opens case; quarantines artifact

Schema Capsule (OC-4) [Normative]

Requirement Level: Optional

Condition: When IR/SIEM integration is present

schema_id=IRPolicyViolationEvent@1.0 | json_schema_uri=uri://schema/ir-policy-violation-1.0.json

Conformance: Normative if implemented or claimed.

OC-5: QuarantineRequest (Artifact Containment) [Informative, optional]

- **Producer(s):** K2
- **Topic/Path:** sec.supplychain.quarantine_request
- **Schema/Format:** QuarantineRequest@1.0 (artifact_digest, reason_code, ttl, scope)
- **Classification:** C2
- **Delivery/Ordering:** at-least-once; per artifact_digest
- **Idempotency-Key:** sha256(artifact_digest, reason_code)

- **Ack/Nack:** quarantine_id created; retry/backoff
- **Side-Effects:** block promotion or deployment until cleared

Schema Capsule (OC-5) [Normative]

Requirement Level: Conditionally Required

Condition: When deployment or intake systems support quarantine gates
 schema_id=QuarantineRequest@1.0 | json_schema_uri=uri://schema/quarantine-request-1.0.json

Conformance: Normative when condition is met.

OC-6: FeedbackIngestionEvent (Stakeholder Feedback Loop) [Informative, optional]

- **Producer(s):** Intake and release portals; K2 (aggregation)
- **Topic/Path:** sec.supplychain.feedback
- **Schema/Format:** FeedbackIngestionEvent@1.0
- **Classification:** C1
- **Delivery/Ordering:** at-least-once; per review_id
- **Idempotency-Key:** sha256(review_id, artifact_digest)
- **Ack/Nack:** feedback_id assigned; retry/backoff
- **Side-Effects:** feeds governance-reviewed learning queue

Schema Capsule (OC-6) [Normative]

Requirement Level: Optional

Condition: When stakeholder feedback workflow is enabled
 schema_id=FeedbackIngestionEvent@1.0 | json_schema_uri=uri://schema/feedback-ingestion-1.0.json

Conformance: Normative if implemented or claimed.

State machine (concise) [Informative]

states = { idle, ingesting_chain, validating_chain, verifying_hash, verifying_attestations, adjudicating, publishing_report, emitting_events, contestation_workflow, failed, closed }
 transition(idle -> ingesting_chain) when certificate chain received
 transition(ingesting_chain -> validating_chain) when AIA fetch complete
 transition(validating_chain -> verifying_hash) when path valid and time valid

transition(verifying_hash -> verifying_attestations) when digest matches manifest
 transition(verifying_attestations -> adjudicating) when Rekor and DSSE checks complete
 transition(adjudicating -> publishing_report) when verdict computed
 transition(publishing_report -> emitting_events) when OC-1 ACK received
 transition(adjudicating -> contestation_workflow) when dispute opened or auto-escalation triggers
 transition(* -> failed) on timeout or validation error
 timeout(validating_chain, 60s) -> failed; retry <= 3 with exp backoff
 idempotency_key = sha256(artifact_digest, verification_profile, policy_version)

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 AuthenticityReport	Required	Always	Gate deployment and intake
OC-2 AuthenticityResultEvent	Conditionally Required	Downstream SBOM/Risk consumers integrated	Pipeline enrichment
OC-3 PolicyDispute	Optional	Contestability enabled	Governance workflow
OC-4 IRPolicyViolationEvent	Optional	IR/SIEM integration present	Incident response
OC-5 QuarantineRequest	Conditionally Required	Quarantine-capable deployment/intake systems	Prevent unsafe promotion
OC-6 FeedbackIngestionEvent	Optional	Stakeholder feedback workflow	Continuous improvement

Requirement Level Definitions:

- **Required:** Must be implemented for conformant deployment
- **Conditionally Required:** Must be implemented when trigger condition is met
- **Optional:** May be implemented for enhanced functionality

Policies and HITL gates [Informative]

- `policy_refs`: NIST 800-161; 800-53 SA-12, SR-3, SR-6, SI-7; SLSA; enterprise PKI policy.
- **HITL required**: revocation ambiguous with `require_revocation_check=true`; transparency outage with `require_transparency_log=true`; expired certs within grace window; conflicting chain paths.
- **Automatic HITL escalation triggers**: `model_confidence < theta_low`; `chain_valid=false` but `alt_path_exists=true`; `rekor_inclusion=false` with `network_ok=true`.

SLOs and KPIs [Informative]

- `ReportAck_p95` ≤ 5 s
- `FalseAcceptRate_30d` ≤ 0.1 percent
- `RevocationCheckCoverage_7d` ≥ 99 percent of verified chains
- `RekorLookupLatency_p95` ≤ 2 s

Outputs index [Informative]

[OC-1 AuthenticityReport], [OC-2 AuthenticityResultEvent], [OC-3 PolicyDispute], [OC-4 IRPolicyViolationEvent], [OC-5 QuarantineRequest], [OC-6 FeedbackIngestionEvent]

Technical Implementation Details (K2) [Informative]

Model and training profile [Informative]

`model_id`=auth-verification-text; `temperature`=0.0; `max_tokens_out`=700

`prompt_pack_id`=auth-verify-v1 (X.509, OCSP/CRL, Sigstore/Rekor, DSSE/SLSA rubrics)

RAG: `sources`={enterprise trust store, revocation policy, builder allowlist, transparency log metadata, validator error catalog}; `max_docs`=8; `min_similarity`=0.80; citations required

`fine_tuning/adapters`: none initially; evaluate on false accept/false reject bounds

`guardrails`: deterministic validators only; no arbitrary code execution; endpoint allowlist

Memory and state [Informative]

`working_memory.max_tokens`=3k; `eviction`=recency_then_importance

`episodic_memory`: per `mission_id` journal (inputs, checks, verdicts), `ttl`=365d

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

semantic_memory: namespaces=["trust-store","revocation","provenance","validators"];
embeddings=text-embedding-sec-v1; k=8
durable_state_store: event-sourced authenticity journal; snapshot per artifact_digest
consistency: exactly-once (OC-1 per artifact_digest + profile); at-least-once (OC-2)
idempotency: as per Output Contracts

Decision and routing logic [Informative]

Definitions:

- $\text{time_valid} = (\text{not_before} - \text{clock_skew_max}) \leq \text{now} \leq (\text{not_after} + \text{clock_skew_max})$
- $\text{chain_valid} = \text{path_to_trust_anchor} \text{ AND } \text{eku_allows_code_signing} \text{ AND } \text{alg_policy_ok}$
- $\text{revocation_ok} = (\text{ocsp_status} == \text{good}) \text{ OR } (\text{crl_status} == \text{not_revoked})$. If $\text{require_revocation_check} = \text{true}$ AND $(\text{ocsp_status} == \text{unknown} \text{ AND } \text{crl_unreachable} == \text{true})$ then $\text{revocation_ok} = \text{unknown}$.
- $\text{hash_ok} = (\text{sha256_computed} == \text{sha256_manifest}) \text{ OR } (\text{sha512_computed} == \text{sha512_manifest})$
- $\text{transparency_ok} = (\text{rekor_inclusion_proof} == \text{valid}) \text{ AND } (\text{fulcio_leaf_valid} == \text{true})$ when $\text{require_transparency_log} = \text{true}$
- $\text{slsa_ok} = (\text{slsa_level} \geq \text{slsa_min_required}) \text{ AND } (\text{builder_id} \text{ in } \text{approved_builders})$

Compute:

$\text{authenticity_score} = 0.30\text{indicator}(\text{chain_valid}) + 0.20\text{indicator}(\text{revocation_ok} == \text{good})$
 $+ 0.20\text{indicator}(\text{hash_ok}) + 0.20\text{indicator}(\text{transparency_ok}) + 0.10*\text{indicator}(\text{slsa_ok})$

Verdict (example policy):

- authentic if $\text{chain_valid} \text{ AND } \text{hash_ok} \text{ AND } (\text{revocation_ok} \text{ in } \{\text{good}, \text{unknown} \text{ when } \text{require_revocation_check} = \text{false}\}) \text{ AND } \text{transparency_ok} \text{ when required AND } \text{slsa_ok}$
- $\text{authentic_with_warnings}$ if $\text{chain_valid} \text{ AND } \text{hash_ok} \text{ AND } (\text{revocation_ok} == \text{unknown}) \text{ AND } (\text{transparency_ok} == \text{false} \text{ but } \text{require_transparency_log} = \text{false})$
- not_authentic otherwise

routing: on authentic → publish OC-1 and OC-2; on not_authentic → publish OC-1, emit OC-5 (quarantine) and optionally OC-4; on dispute → OC-3 and enter contestation_workflow.

Model Risk Management [Informative]

continuous_validation: daily; eval_suite=[goldens, adversarial forged chains, replayed Rekor outages]

thresholds: eval_pass_rate >= 99.5 percent → auto_HITL if below

red_team_cycle: monthly (forged intermediates, hash collision claims)

rollback_policy: eval_drop >= 1.5 percentage points for 48 h → revert model_id; notify owners

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

decision_rationale_template: who/what/why; evidence_refs; chain_summary;

revocation_status; transparency_proofs; hashes

UI/API: expose classification_label, provenance.attestation, decision_rationale_url

audit_log_format: JSONL with stable field order; retention per classification and legal_hold

Incident Response Integration [Informative]

Emit OC-4 on suspected forgery; SOAR quarantines artifact and alerts vendor management.

Stakeholder Feedback Loop [Informative]

Emit OC-6; labels={helpful|neutral|harmful}; apply after governance review to update prompt_pack or policy notes.

Data Sovereignty and Legal Hold [Informative]

Enforce region constraints at ingress; legal_hold=true overrides TTL and blocks purge.

Interfaces (links only) [Informative]

Consumes: X.509 chains; Hash Manifests; Sigstore/in-toto

Produces: OC-1, OC-2, OC-3, OC-4, OC-5, OC-6

Safety and abuse prevention [Informative]

kill_switch on trust-anchor mismatch or signature verification anomalies; sandboxing for parser; QPS limits per mission_id

Testing and validation [Informative]

contract tests for OC-1 and OC-2; offline replay of historical chains and Rekor entries; red-team forged intermediates; drift checks and rollback

Deployment and lifecycle [Informative]

Autoscale by queue depth; canary new validator versions; SBOM + in-toto/SLSA attestations; sign all outputs

References / Standards [Informative]

NIST SP 800-161; NIST SP 800-53 Rev. 5 (SA-12, SR-3, SR-6, SI-7); NIST SP 800-160 Vol. 2; NIST CSF 2.0; SLSA; in-toto; Sigstore; RFC 5280; RFC 6960; MITRE ATT&CK/D3FEND (supply-chain techniques)

MCP-Native Protocol Specification (K2) [Normative]

- **Native Protocol(s) Consumed:** X.509 component certificates (PEM/DER, CRL/OCSP); Hash Manifests (SHA-256/SHA-512); Sigstore/in-toto (Fulcio, Rekor, DSSE).
- **Native Protocol(s) Produced:** AuthenticityReport (REST/gRPC); AuthenticityResultEvent (Kafka/AMQP).
- **MCP Context Fields:**
 - **Required:** mission_id; role="AuthenticityVerificationAgent"; intent="verify"; provenance (SPIFFE ID, signing KID, attestation); policy_refs
 - **Optional:** constraints; classification; decision_basis; legal_hold
- **Enforcement Note:** Deploy and intake PEPs MUST verify a signed AuthenticityReport and enforce constraints; block or quarantine on failure.
- **Versioning and compatibility; producers/consumers registry:** authoritative here; see Schema Capsules for accepted ranges/EOL.
- **Example payloads:** native and MCP-wrapped examples above (authoritative).
- **Transparency hooks:** classification_label, provenance.attestation, decision_rationale_url available to downstream UIs/APIs.

Conformance: This section is **[Normative]** and, together with each **Schema Capsule**, defines testable requirements.

K3. SBOM Analysis Agent

Agent Blueprint [Informative]

Purpose: Parse and analyze SBOMs to enumerate software components, resolve vulnerabilities against feeds (NVD/OSV/KEV), compute component and bill-of-materials risk, and emit an **SBOMRiskReport** with CVE → control mappings for traceability.

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **CycloneDX SBOM (JSON):** components with purls, optional embedded vulnerabilities, licenses.
- **SPDX SBOM (JSON):** packages with externalRefs (purl/CPE), relationships.
- **Vulnerability Feeds (JSON):** NVD (CPE/CVSS vectors), OSV (ecosystem ranges for purls), **CISA KEV** (exploitation-in-the-wild flags).

Model training / knowledge (what the LLM relies on):

- Prompt pack: parsing norms for CycloneDX 1.5 & SPDX 2.3; mapping rules purl↔CPE; de-dup logic CVE/OSV aliasing; control mappings (SI-2, RA-5, CM-6).
- RAG sources: SBOM schema cheat-sheets, internal component registry, vulnerability cache (NVD/OSV mirrors), KEV snapshot, fix-version KB, exploit maturity notes. Do **not** train on regulated evidence; use evidence_refs.
- Guardrails: strict JSON schema validation; MIME allowlist; offline-first feed usage w/ signed mirror snapshots; read-only to production package repos.

Decisions it makes (deterministic + model-assisted):

- **Normalization:** unify CycloneDX/SPDX → component model {name, version, purl?, cpe?}.
- **Vuln resolution:** join by purl (OSV primary) and by cpe (NVD fallback), merge aliases; collapse duplicates.
- **Risk scoring:** compute per-component and BOM-level risk; raise severity when **KEV** flagged; factor EPSS (if available), reachability tags (if supplied), asset criticality.
- **Recommendations:** derive fix versions, compensating controls, and SLA due dates (tighten when KEV=true).

- **Classification:** default C2; elevate to C3 if SBOM contains sensitive internal paths/metadata.

Routing / where outputs go:

- **SBOMRiskReport** → REST/gRPC back to caller (build pipeline, intake scanner, vendor intake).
- **SBOMRiskFinding** events → Kafka/AMQP for Patch Management, Risk Ledger, and Governance Policy agents.
- **(Optional)** Remediation ticket requests → ITSM if integrated.

Automation scope vs. manual/HITL:

- Fully automated: schema validation, normalization, feed lookups/joins, de-dup, scoring, report/event emission.
- **HITL required:** contested purl↔CPE mappings; conflicting fix versions; KEV-critical items where remediation would break availability; any **risk acceptance** decisions.
- Manual outside agent: product team impact assessments; coordinated disclosure with suppliers.

Security Domain: Supply Chain & Lifecycle Security

Inputs (native protocols consumed) [Informative]

1. **CycloneDX SBOM (JSON)** — component inventory with purls and optional embedded vulnerabilities.
2. **SPDX SBOM (JSON)** — package inventory with externalRefs (purl/CPE).
3. **Vulnerability Feeds (NVD/OSV + CISA KEV)** — JSON records for resolution and exploitation flags.

Example: Consumed Protocol — CycloneDX SBOM (JSON) [Informative]

Native payload

```
{
  "bomFormat": "CycloneDX",
  "specVersion": "1.5",
  "version": 1,
```

```
"components": [  
  {"type": "library", "name": "openssl", "version": "1.1.1w", "purl":  
"pkg:generic/openssl@1.1.1w"},  
  {"type": "library", "name": "log4j-core", "version": "2.18.0", "purl":  
"pkg:maven/org.apache.logging.log4j/log4j-core@2.18.0"}  
]  
}
```

MCP-wrapped payload

```
{  
  "mcp_context": {  
    "mcp_version": "0.9",  
    "mission_id": "uuid-k3-cdx-1111-2222-3333-4444",  
    "thread_id": "uuid-sbom-cdx-app-portal-1.0.0",  
    "task_id": "uuid-aa11-bb22-cc33-dd44",  
    "role": "SBOMAnalysisAgent",  
    "intent": "assess",  
    "policy_refs": ["SI-2", "RA-5", "CM-6"],  
    "constraints": ["region:US"],  
    "decision_basis": {  
      "evidence_refs": ["uri://sboms/cyclonedx/app-portal-1.0.0.cdx.json"],  
      "confidence": 0.98,  
      "explanation_ref": "uri://kb/sbom/parsing#cyclonedx-1.5"  
    },  
    "provenance": {  
      "producer_spiffe": "spiffe://enterprise/supplychain/sbom-analysis-agent",  
      "signing_kid": "kid-cdx-01",  
      "attestation_ref": "uri://slsa/attestations/sbom-analysis@sha256:cdx01"  
    }  
  }  
}
```

```

    },
    "classification": "C2",
    "legal_hold": false
  },
  "native_payload": { ... }
}

```

Example: Consumed Protocol — SPDX SBOM (JSON) [Informative]

Native payload

```

{
  "spdxVersion": "SPDX-2.3",
  "name": "app-portal",
  "packages": [
    {
      "name": "nginx",
      "versionInfo": "1.25.2",
      "downloadLocation": "https://nginx.org/download/nginx-1.25.2.tar.gz",
      "externalRefs": [
        {
          "referenceCategory": "PACKAGE-MANAGER", "referenceType": "purl",
          "referenceLocator": "pkg:generic/nginx@1.25.2"
        }
      ]
    }
  ]
}

```

MCP-wrapped payload

```

{
  "mcp_context": {
    "mcp_version": "0.9",

```

```

"mission_id": "uuid-k3-spx-5555-6666-7777-8888",
"thread_id": "uuid-sbom-spx-app-portal-1.0.0",
"task_id": "uuid-9911-8822-7733-6644",
"role": "SBOMAnalysisAgent",
"intent": "assess",
"policy_refs": ["SI-2", "RA-5"],
"decision_basis": {
  "evidence_refs": ["uri://sboms/spx/app-portal-1.0.0.spx.json"],
  "confidence": 0.97,
  "explanation_ref": "uri://kb/sbom/parsing#spx-2.3"
},
"provenance": {
  "producer_spiffe": "spiffe://enterprise/supplychain/sbom-analysis-agent",
  "signing_kid": "kid-spx-02",
  "attestation_ref": "uri://slsa/attestations/sbom-analysis@sha256:spx02"
},
"classification": "C2",
"legal_hold": false
},
"native_payload": { ... }
}

```

Example: Consumed Protocol — Vulnerability Feeds (NVD/OSV + KEV)

[Informative]

NVD excerpt

```

{
  "cve": {"id": "CVE-2025-12345"},
  "metrics": {"cvssV3_1": {"baseScore": 9.8, "baseSeverity": "CRITICAL"}},

```

```

"configurations":
{"nodes":[{"cpeMatch":[{"vulnerable":true,"criteria":"cpe:2.3:a:apache:http_server:*:*:*:*:*:*:*","versionEndExcluding":"2.4.60"}]}]},

"references": [{"url":"https://httpd.apache.org/security/vulnerabilities_24.html"}]
}

```

OSV record

```

{
  "id": "OSV-2025-00077",
  "aliases": ["CVE-2025-22222"],
  "affected": [{
    "package": {"ecosystem": "Maven", "name": "org.apache.logging.log4j:log4j-core"},
    "ranges": [{"type": "ECOSYSTEM", "events":[{"introduced":"0"}, {"fixed":"2.22.0"}]}],
    "versions": ["2.10.0", "2.17.1", "2.18.0"]
  }]
}

```

CISA KEV flag

```

{ "cve_id": "CVE-2025-22222", "date_added": "2025-08-15", "due_date": "2025-09-05",
  "known_ransomware_campaigns": true }

```

Outputs (native) [Informative]

- **REST/gRPC SBOMRiskReport:** per-component CVE set, KEV flags, risk score, recommended actions, CVE→control mappings.
- **Kafka/AMQP SBOMRiskFinding:** normalized per-finding events for Patch/Risk agents.

MCP context (required) [Informative]

mission_id; role="SBOMAnalysisAgent"; intent="assess"; provenance (SPIFFE ID, signing KID, attestation)

MCP context (optional) [Informative]

policy_refs (e.g., SI-2, RA-5, CM-6); constraints (e.g., "region:US", "no_publish_raw_pii"); classification (C2); decision_basis (evidence_refs, confidence, cve_control_map, explanation_ref); legal_hold

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

Enforcement note [Informative]

Release/Intake PEPs MUST require an **SBOMRiskReport** and block promotion when **KEV-critical** or policy-violating risk persists without approved remediation or risk acceptance.

NIST SP 800-160v2 linkage [Informative]

Supports resilient dependency management via vulnerability detection, traceability, and governed remediation.

Automation feasibility [Informative]

High (schema-driven parsing and deterministic joins; HITL only for contested mappings/acceptance).

Output Contracts (merged) [Informative]

OC-1: SBOMRiskReport (REST/gRPC) [Informative]

- **Producer(s):** K3
- **Endpoint/Path:** POST /sbom/v1/report or gRPC SBOM.Analyze
- **Schema/Format:** SBOMRiskReport@1.0 { bom_id, bom_digest, components[], findings[], kev_summary, bom_risk_score, recommendations[], cve_control_map[], constraints_applied[], signature, provenance }
- **Classification:** C2
- **Delivery:** exactly-once per bom_digest + policy_version
- **Ordering:** per bom_id
- **Idempotency-Key:** sha256(bom_digest, policy_version)
- **Ack/Nack:** 2xx or gRPC OK is ACK; 4xx/5xx NACK → retry/backoff and open ticket
- **Timeouts/Retry:** ack≤10s; exp-backoff≤5x
- **Side-Effects:** write report to risk registry; attach summary to CI/portal
- **HITL Token:** required to mark KEV-critical as accepted risk
- **Observability:** trace_id, mission_id, policy_refs, decision_basis.*, classification_label, provenance.attestation
- **Retention/TTL:** 7 years

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=SBOMRiskReport@1.0 | json_schema_uri=uri://schema/sbom-risk-report-1.0.json | sha256= | producers=K3 | consumers=Deploy-PEP-01, RiskLedger-01 | accepts=1.0–1.x

Conformance: Normative.

OC-2: SBOMRiskFinding (Kafka/AMQP) [Informative]

- **Producer(s):** K3
- **Topic/Path:** sec.supplychain.sbom.finding
- **Schema/Format:** SBOMRiskFinding@1.0 { bom_id, component_purl, cve_id, severity, kev, epss?, fix_version?, control_refs[], report_uri }
- **Classification:** C2
- **Delivery:** at-least-once
- **Ordering:** per component_purl
- **Idempotency-Key:** sha256(bom_id, component_purl, cve_id)
- **Ack/Nack:** broker ACK; NACK → retry/backoff
- **Side-Effects:** triggers patch pipelines; opens ITSM sub-tasks if integrated

Schema Capsule (OC-2) [Normative]

Requirement Level: Conditionally Required

Condition: When downstream consumers (Patch/Risk systems) subscribe

schema_id=SBOMRiskFinding@1.0 | json_schema_uri=uri://schema/sbom-risk-finding-1.0.json | sha256= | producers=K3 | consumers=Patch-01, Risk-01 | accepts=1.0–1.x

Conformance: Normative when condition is met.

OC-3: PolicyDispute (Explainability and Contestability) [Informative, optional]

- **Producer(s):** K3, Legal/Compliance portals
- **Topic/Path:** sec.supplychain.sbom.contestation
- **Schema/Format:** PolicyDispute@1.0 (target=cve_id|component|bom_id; rationale_url; attachments)

- **Classification:** C2+
- **Delivery/Ordering:** at-least-once; per target id
- **Idempotency-Key:** sha256(target_id, dispute_id)
- **Side-Effects:** pause promotion for disputed items; route to governance review

Schema Capsule (OC-3) [Normative]

Requirement Level: Optional

Condition: When contestability is enabled

schema_id=PolicyDispute@1.0 | json_schema_uri=uri://schema/policy-dispute-1.0.json

Conformance: Normative if implemented or claimed.

OC-4: IRPolicyViolationEvent (Exploit-critical) [Informative, optional]

- **Producer(s):** K3
- **Topic/Path:** sec.supplychain.incident
- **Schema/Format:** IRPolicyViolationEvent@1.0 { bom_id, cve_id, kev=true, affected_assets[], indicator, severity }
- **Classification:** C2
- **Delivery/Ordering:** at-least-once; per incident_id

Schema Capsule (OC-4) [Normative]

Requirement Level: Optional

Condition: When IR/SIEM integration is present

schema_id=IRPolicyViolationEvent@1.0 | json_schema_uri=uri://schema/ir-policy-violation-1.0.json

Conformance: Normative if implemented or claimed.

OC-5: RemediationTicketRequest (ITSM) [Informative, optional]

- **Producer(s):** K3 (based on policy/SLA)
- **Topic/Path:** sec.supplychain.remediation_request
- **Schema/Format:** RemediationTicketRequest@1.0 { bom_id, component_purl, cve_id, fix_version, due_date, sla_reason, kev, assignee_group }
- **Classification:** C2
- **Delivery/Ordering:** at-least-once; per cve_id

- **Idempotency-Key:** sha256(bom_id, component_purl, cve_id)
- **Side-Effects:** creates ITSM tickets and links to report

Schema Capsule (OC-5) [Normative]

Requirement Level: Conditionally Required

Condition: When ITSM integration is enabled for automated remediation workflow

schema_id=RemediationTicketRequest@1.0 |

json_schema_uri=uri://schema/remediation-ticket-request-1.0.json

Conformance: Normative when condition is met.

OC-6: FeedbackIngestionEvent (Stakeholder Feedback Loop) [Informative, optional]

- **Producer(s):** Engineering/Owner portals; K3 (aggregation)
- **Topic/Path:** sec.supplychain.feedback
- **Schema/Format:** FeedbackIngestionEvent@1.0 { review_id, bom_id, component_purl, label, comment_uri }
- **Classification:** C1
- **Delivery/Ordering:** at-least-once; per review_id

Schema Capsule (OC-6) [Normative]

Requirement Level: Optional

Condition: When stakeholder feedback workflow is enabled

schema_id=FeedbackIngestionEvent@1.0 | json_schema_uri=uri://schema/feedback-ingestion-1.0.json

Conformance: Normative if implemented or claimed.

State machine (concise) [Informative]

states = { idle, validating_sbom, normalizing_components, resolving_vulns, computing_risk, publishing_report, emitting_findings, contestation_workflow, failed, closed }

transition(idle -> validating_sbom) when SBOM ingested

transition(validating_sbom -> normalizing_components) when schema OK

transition(normalizing_components -> resolving_vulns) when purls/cpes extracted

transition(resolving_vulns -> computing_risk) when NVD/OSV joins complete and KEV flags applied

transition(computing_risk -> publishing_report) when scores computed

transition(publishing_report -> emitting_findings) on OC-1 ACK
 transition(computing_risk -> contestation_workflow) on dispute or auto-escalation
 transition(* -> failed) on schema error/feed timeout
 timeout(resolving_vulns, 60s) -> failed; retry <= 3 with exp backoff
 idempotency_key = sha256(bom_digest, policy_version)

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 SBOMRiskReport	Required	Always	Gate promotion; auditability
OC-2 SBOMRiskFinding	Conditionally Required	Downstream Patch/Risk consumers present	Drive remediation workflows
OC-3 PolicyDispute	Optional	Contestability enabled	Governance workflow
OC-4 IRPolicyViolationEvent	Optional	IR/SIEM integration present	Incident response
OC-5 RemediationTicketRequest	Conditionally Required	ITSM integration enabled	Automated ticketing/SLA tracking
OC-6 FeedbackIngestionEvent	Optional	Stakeholder feedback workflow	Continuous improvement

Requirement Level Definitions:

- **Required:** Must be implemented for conformant deployment
- **Conditionally Required:** Must be implemented when trigger condition is met
- **Optional:** May be implemented for enhanced functionality

Policies and HITL gates [Informative]

- policy_refs: SI-2, RA-5, CM-6; org risk policy (KEV/SLA rules).

- **HITL required:** risk acceptance of KEV-critical; disputed mappings; fix-version conflicts.
- **Automatic HITL escalation triggers:** kev=true; epss>=0.7; model_confidence < theta_low; stakeholder_disagreement_score >= 0.5.

SLOs and KPIs [Informative]

- ReportAck_p95 <= 10 s
- VulnResolutionCoverage_24h >= 99 percent of components with purl or cpe
- KEVTimeToTicket_p95 <= 30 min
- FalsePositiveRate_30d <= 2 percent

Outputs index [Informative]

[OC-1 SBOMRiskReport], [OC-2 SBOMRiskFinding], [OC-3 PolicyDispute], [OC-4 IRPolicyViolationEvent], [OC-5 RemediationTicketRequest], [OC-6 FeedbackIngestionEvent]

Technical Implementation Details (K3) [Informative]

Model and training profile [Informative]

model_id=sbom-analysis-text; temperature=0.1; max_tokens_out=900
 prompt_pack_id=sbom-analysis-v1 (CycloneDX/SPDX parsing, purl↔CPE mapping, de-dup, control mapping)
 RAG: sources={schema refs, component registry, NVD/OSV mirrors, KEV list, fix-version KB}; max_docs=8; min_similarity=0.78; citations required
 fine_tuning/adapters: none initially; eval on parsing accuracy, mapping precision, recommendation quality
 guardrails: schema validation; bounded joins; signed feed snapshots only

Memory and state [Informative]

working_memory.max_tokens=4k; eviction=recency_then_importance
 episodic_memory: per mission_id journal (SBOM digest, joins, findings), ttl=365d
 semantic_memory: namespaces=["components","vulns","controls"]; embeddings=text-embedding-sec-v1; k=8
 durable_state_store: event-sourced risk ledger; snapshot per report version
 consistency: exactly-once (OC-1 per bom_digest+policy_version); at-least-once (OC-2/OC-5)
 idempotency: per Output Contracts

Decision and routing logic [Informative]

Let:

- $cvss$ = normalized CVSS base score in $[0,10]$ (use CVSS v3.1 if present else v2 mapped).
- kev = 1 if CVE is in KEV, else 0.
- $epss$ = Exploit Prediction Scoring System probability in $[0,1]$ (if available else 0).
- $reach$ = 1 if vulnerable code path is reachable (e.g., via SCA call-graph), else 0 (if unknown, 0.5).
- $criticality$ = asset/component criticality in $[0,1]$.
- age_fix = $\min(1, days_since_fix / 30)$ (older fixes increase urgency).

$component_risk_score = 0.35(cvss/10) + 0.25kev + 0.15epss + 0.15reach + 0.10criticality + 0.05age_fix^{**}$

bom_risk_score = weighted_mean(component_risk_score, weights = component_criticality)

Policy example:

- mark **critical** if $kev=1$ OR $component_risk_score \geq 0.70$
- recommend **fix_version** from OSV ranges when available; else vendor advisory.
- map controls via **cve_control_map**: $\{cve_id \rightarrow [SI-2, RA-5, CM-6]\}$.

routing: emit OC-1; if consumers present emit OC-2 per finding; if kev or severity critical and ITSM integrated emit OC-5; on suspected active exploitation emit OC-4; disputes $\rightarrow$ OC-3.

Model Risk Management [Informative]

continuous_validation: daily; eval_suite=[goldens (known SBOMs), adversarial malformed SBOMs, aliasing traps]

thresholds: $eval_pass_rate \geq 99.0$ percent $\rightarrow$ auto_HITL if below

red_team_cycle: monthly (purl spoofing, CPE over-matching)

rollback_policy: $eval_drop \geq 1.5$ pp for 48 h $\rightarrow$ revert model_id

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

decision_rationale_template: who/what/why, evidence_refs, feed snapshot hashes, CVE $\rightarrow$ control table

UI/API: expose classification_label, provenance.attestation, decision_rationale_url
audit_log_format: JSONL stable fields; retention per classification/legal_hold

Incident Response Integration [Informative]

Emit OC-4 on KEV-critical with affected_assets; SOAR links to patch tasks.

Stakeholder Feedback Loop [Informative]

Emit OC-6 with labels={helpful|neutral|harmful}; apply to prompt/rubric after governance review; never auto-train on regulated SBOMs.

Data Sovereignty and Legal Hold [Informative]

Honor constraints.region at ingress; legal_hold=true freezes purge and extends TTL.

Interfaces (links only) [Informative]

Consumes: CycloneDX 1.5; SPDX 2.3; NVD/OSV/KEV feeds

Produces: OC-1, OC-2, OC-3, OC-4, OC-5, OC-6

Safety and abuse prevention [Informative]

kill_switch on unsigned/mismatched feed snapshots; schema-poisoning detection; QPS limits by mission_id

Testing and validation [Informative]

contract tests for OC-1/OC-2; offline replay against historical SBOMs; alias/merge de-dup tests; drift checks and rollback

Deployment and lifecycle [Informative]

HPA on queue depth; canary for mapping/score rules; SBOM for service; in-toto/SLSA attestations; sign all outputs

References / Standards [Informative]

NIST SP 800-161; NIST SP 800-53 Rev. 5 (SA-11/12, SI-2, RA-5, CM-6); NIST SP 800-160 Vol. 2; NIST CSF 2.0; CISA KEV; CycloneDX 1.5; SPDX 2.3; CVSS v3.1; OSV; MITRE ATT&CK/D3FEND

MCP-Native Protocol Specification (K3) [Normative]

- **Native Protocol(s) Consumed:** CycloneDX SBOM (JSON); SPDX SBOM (JSON); NVD/OSV feeds; CISA KEV.

- **Native Protocol(s) Produced:** SBOMRiskReport (REST/gRPC); SBOMRiskFinding (Kafka/AMQP).
- **MCP Context Fields:**
 - **Required:** mission_id; role="SBOMAnalysisAgent"; intent="assess"; provenance (SPIFFE ID, signing KID, attestation)
 - **Optional:** policy_refs; constraints; classification; decision_basis; legal_hold
- **Enforcement Note:** Promotion/Deploy PEPs MUST require a signed SBOMRiskReport and enforce policy thresholds (KEV, critical scores) or documented risk acceptance.
- **Versioning and compatibility; producers/consumers registry:** authoritative here; see Schema Capsules for acceptance ranges/EOL.
- **Example payloads:** native and MCP-wrapped examples above (authoritative).
- **Transparency hooks:** classification_label, provenance.attestation, decision_rationale_url available to downstream UIs/APIs.

Conformance: This section is **[Normative]** and, together with each **Schema Capsule**, defines testable requirements.

K4. SECURE DISPOSAL AGENT

Agent Blueprint [Informative]

Purpose: Coordinate and verify secure end-of-life handling for assets (IT/OT/media/devices): select NIST 800-88 sanitization method, block if under legal hold, track chain-of-custody, and emit a signed **DisposalCertificate**.

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **Disposal Orders** (ERP/Asset Mgmt): approved work orders, scheduled windows, vendor, asset lists, attachments (photos, COI).
- **Asset Inventory** (CMDB/Inventory): classification, media type, encryption status, last backup, chain_of_custody_id, location.
- **Legal Hold / eDiscovery:** active holds by asset or scope; authoritative “gate” prior to any sanitization.

Model training / knowledge (what the LLM relies on):

- Prompt pack: NIST 800-88 Rev.1 method selection rules (clear | purge | destroy), media-type and encryption decision tables, chain-of-custody rubric, legal-hold gating, witness/evidence checklists.
- RAG sources: disposal policy handbook, CMDB schemas, ERP work-order schemas, vendor accreditation list, evidence catalog (photo/video, wipe logs), exception workflow KB. Do not train on real evidence; use evidence_refs.
- Guardrails: write access only to certificate repository and event bus; deny any API that changes CMDB ownership or legal-hold state; file-type allowlist for evidence (png/jpg/mp4/pdf/log).

Decisions it makes (deterministic + model-assisted):

- **Method selection (800-88):** choose clear/purge/destroy per media_type, data_classification, encryption_at_rest, sanitization_category, and policy constraints (e.g., require_witness).
- **Legal-hold gate:** block if legal_hold=true or scope intersects asset media.
- **Chain-of-custody (CoC):** verify custody transitions (pickup → transit → onsite processing → storage/destruction → certification) and witness presence if required.
- **Certificate issuance:** sign a **DisposalCertificate** including method, CoC steps, evidence hashes, witnesses, location/time, and policy_refs.
- **Eventing:** publish **DisposalEvent** transitions; raise IR event on tamper/CoC break.

Routing / where outputs go:

- **DisposalCertificate** → REST/gRPC to requestor and records repository; link in ERP order.
- **DisposalEvent** → Kafka/AMQP (scheduled → in_progress → sanitized → certified or blocked_legal_hold → closed).
- **(Optional)** Custody handoff receipts and evidence bundles → archive/e-discovery bucket.

Automation scope vs. manual/HITL:

- Fully automated: method selection, legal-hold gating, evidence validation (hash/time/location), certificate signing, event publication.
- **HITL required:** physical witness confirmation, atypical media (proprietary OT), conflicting inventory vs. order, evidence gaps, suspected tamper.

- Manual outside agent: vendor dispatch, physical destruction, video capture.

Security Domain: Supply Chain & Lifecycle Security

Inputs (native protocols consumed) [Informative]

1. **Disposal Orders (ERP/Asset Mgmt REST/GraphQL)** — approved work orders and asset lists.
2. **Asset Inventory (CMDB/Inventory REST/GraphQL)** — asset metadata (classification, media type, encryption, ownership).
3. **Legal Hold / eDiscovery (REST)** — active legal/regulatory holds.

Example: Consumed Protocol — Disposal Orders [Informative]

Native payload (work order)

```
{
  "order_id": "DISP-2025-00419",
  "requested_by": "it.asset.ops",
  "scheduled_window": "2025-09-03T01:00:00Z/2025-09-03T05:00:00Z",
  "site": "DC-USE1-A",
  "vendor": "EcoShred Secure",
  "assets": [
    {"asset_id": "laptop-00277", "serial": "C02ZX17NML7P", "media_type": "SSD",
    "requested_method": "purge"},
    {"asset_id": "srv-disk-19", "serial": "Z9A41K3F", "media_type": "HDD",
    "requested_method": "destroy"}
  ],
  "attachments": [
    {"name": "dock_photoset.zip", "uri": "s3://disposal/orders/DISP-2025-00419/photos.zip", "sha256": "aa11..."},
    {"name": "vendor_COI.pdf", "uri": "s3://disposal/orders/DISP-2025-00419/vendor_COI.pdf", "sha256": "bb22..."}
  ]
}
```

```
}
```

MCP-wrapped payload

```
{
```

```
"mcp_context": {  
  "mcp_version": "0.9",  
  "mission_id": "uuid-k4-disp-1111-2222-3333-4444",  
  "thread_id": "uuid-order-DISP-2025-00419",  
  "task_id": "uuid-aa11-bb22-cc33-dd44",  
  "role": "SecureDisposalAgent",  
  "intent": "dispose",  
  "policy_refs": ["NIST-800-88", "NIST-800-53 MP-6", "ORG-DISP-01"],  
  "constraints": ["require_witness:true", "region:US"],  
  "decision_basis": {  
    "evidence_refs": [  
      "uri://erp/disposal/orders/DISP-2025-00419",  
      "s3://disposal/orders/DISP-2025-00419/photos.zip",  
      "s3://disposal/orders/DISP-2025-00419/vendor_COI.pdf"  
    ],  
    "confidence": 0.97,  
    "explanation_ref": "uri://kb/disposal/work-order-checks"  
  },  
  "provenance": {  
    "producer_spiffe": "spiffe://enterprise/supplychain/secure-disposal-agent",  
    "signing_kid": "kid-disp-01",  
    "attestation_ref": "uri://slsa/attestations/secure-disposal@sha256:order01"  
  },  
  "classification": "C2",
```

```
    "legal_hold": false
  },
  "native_payload": { ... }
}
```

Example: Consumed Protocol — Asset Inventory (CMDB) [Informative]

Native payload

```
{
  "asset_id": "laptop-00277",
  "owner": "E102993",
  "business_service": "Engineering",
  "environment": "corporate",
  "data_classification": ["PII"],
  "encryption_at_rest": true,
  "last_backup_ts": "2025-08-25T23:55:00Z",
  "media_type": "SSD",
  "sanitization_category": "purge",
  "chain_of_custody_id": "coc-7f11b2",
  "location": "NYC-Office-4F"
}
```

MCP-wrapped payload

```
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-k4-cmdb-5555-6666-7777-8888",
    "thread_id": "uuid-asset-laptop-00277",
    "task_id": "uuid-9911-8822-7733-6644",
    "role": "SecureDisposalAgent",
  }
}
```

```

"intent": "dispose",
"policy_refs": ["NIST-800-88", "CM-8", "MP-6"],
"constraints": ["method:purge", "require_witness:true"],
"decision_basis": {
  "evidence_refs": ["uri://cmdb/assets/laptop-00277"],
  "confidence": 0.96,
  "explanation_ref": "uri://kb/disposal/method-selection#800-88"
},
"provenance": {
  "producer_spiffe": "spiffe://enterprise/supplychain/secure-disposal-agent",
  "signing_kid": "kid-cmdb-02",
  "attestation_ref": "uri://slsa/attestations/secure-disposal@sha256:cmdb02"
},
"classification": "C3",
"legal_hold": false
},
"native_payload": { ... }
}

```

Example: Consumed Protocol — Legal Hold / eDiscovery [Informative]

Native payload

```

{
  "asset_id": "laptop-00277",
  "holds": [
    {"hold_id": "LH-2025-019", "scope": "all_media", "reason": "litigation", "active": false},
    {"hold_id": "LH-2025-021", "scope": "email_archives", "reason": "regulatory", "active": true}
  ],

```

```

    "checked_at": "2025-08-28T12:30:00Z"
  }
  MCP-wrapped payload
  {
    "mcp_context": {
      "mcp_version": "0.9",
      "mission_id": "uuid-k4-legal-9999-aaaa-bbbb-cccc",
      "thread_id": "uuid-legalhold-laptop-00277",
      "task_id": "uuid-1122-3344-5566-7788",
      "role": "SecureDisposalAgent",
      "intent": "dispose",
      "policy_refs": ["MP-6", "ORG-DISP-LEGAL-HOLD"],
      "constraints": ["must_false:legal_hold"],
      "decision_basis": {
        "evidence_refs": ["uri://legalhold/assets/laptop-00277/status/2025-08-28T12:30:00Z"],
        "confidence": 0.99,
        "explanation_ref": "uri://kb/disposal/legal-hold-gate"
      },
      "provenance": {
        "producer_spiffe": "spiffe://enterprise/supplychain/secure-disposal-agent",
        "signing_kid": "kid-legal-03",
        "attestation_ref": "uri://slsa/attestations/secure-disposal@sha256:legal03"
      },
      "classification": "C2",
      "legal_hold": true
    },
  },

```

```
"native_payload": { ... }  
}
```

Note: When `legal_hold=true`, the agent **MUST** block destruction and emit a **blocked_legal_hold** status until cleared.

Outputs (native) [Informative]

- **REST/gRPC DisposalCertificate:** method, chain-of-custody, witnesses, evidence refs, signatures.
- **Kafka/AMQP DisposalEvent:** status transitions and context (`asset_id`, `order_id`, timestamps, who, where).

MCP context (required) [Informative]

`mission_id`; `role="SecureDisposalAgent"`; `intent="dispose"`; `provenance` (SPIFFE ID, signing KID, attestation); `policy_refs` (NIST 800-88; NIST 800-53 MP-6/MP-5; CM-8; ORG-DISP-xx)

MCP context (optional) [Informative]

`constraints` (e.g., `"require_witness:true"`, `"method:purge|destroy"`, `"region:US"`, `"evidence:photos"`); `classification` (C2–C3); `decision_basis` (`evidence_refs`, `confidence`, `explanation_ref`)

Enforcement note [Informative]

PEPs **MUST** verify `legal_hold=false` and a valid chain-of-custody before any sanitize/destroy action; certificate signatures and provenance **MUST** be validated prior to closure.

NIST SP 800-160v2 linkage [Informative]

Supports “recover and adapt” via assured sanitization, tamper-evident custody, and authoritative certification.

Automation feasibility [Informative]

High (policy translation and evidence validation are deterministic; physical acts require HITL/witness).

Output Contracts (merged) [Informative]

OC-1: DisposalCertificate (REST/gRPC) [Informative]

- **Producer(s):** K4

- **Endpoint/Path:** POST /disposal/v1/certificate or gRPC Disposal.Certify
- **Schema/Format:** DisposalCertificate@1.0 { order_id, asset_id, method, method_basis, media_type, classification, legal_hold_checked_at, chain_of_custody[], witnesses[], evidence_refs[], location, started_at, completed_at, policy_refs[], signature, provenance }
- **Classification:** C2–C3
- **Delivery:** exactly-once per (order_id, asset_id)
- **Ordering:** per order_id
- **Idempotency-Key:** sha256(order_id, asset_id, method, completed_at)
- **Ack/Nack:** 2xx or gRPC OK = ACK; else retry/backoff and open exception ticket
- **Timeouts/Retry:** ack<=10s; exp-backoff<=5x
- **Side-Effects:** archive evidence bundle; update ERP order; notify records management
- **HITL Token:** required if require_witness=true and witness_attested=false
- **Observability:** trace_id, mission_id, policy_refs, decision_basis.*, classification_label, provenance.attestation
- **Retention/TTL:** 7 years (or legal_hold override)

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=DisposalCertificate@1.0 | json_schema_uri=uri://schema/disposal-certificate-1.0.json | sha256= | producers=K4 | consumers=ERP-Disposal-01, Records-01 | accepts=1.0–1.x

Conformance: Normative.

OC-2: DisposalEvent (Kafka/AMQP) [Informative]

- **Producer(s):** K4
- **Topic/Path:** sec.lifecycle.disposal.event
- **Schema/Format:** DisposalEvent@1.0 { order_id, asset_id, status, ts, site, vendor_id, reason?, custody_step?, evidence_refs[] }
- **Classification:** C2

- **Delivery:** at-least-once
- **Ordering:** per (order_id, asset_id)
- **Idempotency-Key:** sha256(order_id, asset_id, status, ts_floor_60s)
- **Ack/Nack:** broker ACK; NACK → retry/backoff
- **Side-Effects:** drive dashboards/SLA metrics; trigger next workflow state

Schema Capsule (OC-2) [Normative]

Requirement Level: Conditionally Required

Condition: When event bus integration is present

schema_id=DisposalEvent@1.0 | json_schema_uri=uri://schema/disposal-event-1.0.json | sha256= | producers=K4 | consumers=OpsDash-01, SLA-01 | accepts=1.0–1.x

Conformance: Normative when condition is met.

OC-3: PolicyDispute (Explainability and Contestability) [Informative, optional]

- **Producer(s):** K4, Legal/Compliance portals
- **Topic/Path:** sec.lifecycle.disposal.contestation
- **Schema/Format:** PolicyDispute@1.0 { target=asset_id|order_id, rationale_url, attachments[] }
- **Classification:** C2+
- **Delivery/Ordering:** at-least-once; per target

Schema Capsule (OC-3) [Normative]

Requirement Level: Optional

Condition: When contestability is enabled

schema_id=PolicyDispute@1.0 | json_schema_uri=uri://schema/policy-dispute-1.0.json

Conformance: Normative if implemented or claimed.

OC-4: IRPolicyViolationEvent (Custody Break/Tamper) [Informative, optional]

- **Producer(s):** K4
- **Topic/Path:** sec.lifecycle.incident
- **Schema/Format:** IRPolicyViolationEvent@1.0 { order_id, asset_id, indicator, details, severity }

- **Classification:** C2

Schema Capsule (OC-4) [Normative]

Requirement Level: Optional

Condition: When IR/SIEM integration is present

schema_id=IRPolicyViolationEvent@1.0 | json_schema_uri=uri://schema/ir-policy-violation-1.0.json

Conformance: Normative if implemented or claimed.

OC-5: CustodyHandoffReceipt (Vendor Exchange) [Informative, optional]

- **Producer(s):** K4 (on vendor pickup/drop-off)
- **Topic/Path:** sec.lifecycle.custody.handoff
- **Schema/Format:** CustodyHandoffReceipt@1.0 { order_id, asset_id, from_party, to_party, ts, geo, witness, doc_refs[], photo_hashes[] }
- **Classification:** C2

Schema Capsule (OC-5) [Normative]

Requirement Level: Conditionally Required

Condition: When third-party vendor participates in custody chain

schema_id=CustodyHandoffReceipt@1.0 | json_schema_uri=uri://schema/custody-handoff-1.0.json

Conformance: Normative when condition is met.

OC-6: EvidenceBundle (Archive Reference) [Informative, optional]

- **Producer(s):** K4
- **Topic/Path:** sec.lifecycle.disposal.evidence
- **Schema/Format:** EvidenceBundle@1.0 { order_id, asset_id, bundle_uri, manifest_sha256, items[{name,sha256,mime}] }
- **Classification:** C2–C3

Schema Capsule (OC-6) [Normative]

Requirement Level: Optional

Condition: When evidence archiving is enabled

schema_id=EvidenceBundle@1.0 | json_schema_uri=uri://schema/evidence-bundle-1.0.json

Conformance: Normative if implemented or claimed.

State machine (concise) [Informative]

states = { idle, validating_order, gating_legal_hold, selecting_method, scheduling, in_progress, sanitizing, certifying, emitting_events, blocked_legal_hold, contestation_workflow, failed, closed }

transition(idle -> validating_order) when work order received

transition(validating_order -> gating_legal_hold) when assets resolved

transition(gating_legal_hold -> blocked_legal_hold) when legal_hold=true

transition(gating_legal_hold -> selecting_method) when legal_hold=false

transition(selecting_method -> scheduling) when method determined

transition(scheduling -> in_progress) at window start and custody established

transition(in_progress -> sanitizing) when evidence prechecks pass

transition(sanitizing -> certifying) when wipe/destroy complete and evidence verified

transition(certifying -> emitting_events) when OC-1 ready

transition(emitting_events -> closed) when OC-2 ACK and archive complete

transition(* -> contestation_workflow) on dispute or auto-escalation

transition(* -> failed) on evidence gap/timeouts

timeout(sanitizing, 4h) -> failed; retry <= 1 with exp backoff

idempotency_key = sha256(order_id, asset_id, status, ts_floor_60s)

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 DisposalCertificate	Required	Always	Authoritative proof of sanitization
OC-2 DisposalEvent	Conditionally Required	Event bus integration present	Workflow orchestration & telemetry
OC-3 PolicyDispute	Optional	Contestability enabled	Governance/appeals workflow
OC-4 IRPolicyViolationEvent	Optional	IR/SIEM integration present	Incident response on custody breaks

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-5 CustodyHandoffReceipt	Conditionally Required	Third-party vendor participates in custody	Chain-of-custody assurance
OC-6 EvidenceBundle	Optional	Evidence archiving enabled	Audit and e-discovery readiness

Requirement Level Definitions:

- **Required:** Must be implemented for conformant deployment
- **Conditionally Required:** Must be implemented when trigger condition is met
- **Optional:** May be implemented for enhanced functionality

Policies and HITL gates [Informative]

- policy_refs: NIST 800-88; MP-6/MP-5; CM-8; ORG-DISP-xx.
- **HITL required:** require_witness=true and witness not verified; atypical media; evidence mismatch; GPS geofence violation; contested destruction.
- **Automatic HITL escalation triggers:** model_confidence < theta_low; custody_gap_detected=true; evidence_hash_mismatch=true; legal_hold_state_changed_during_window=true.

SLOs and KPIs [Informative]

- CertificateAck_p95 <= 10 s
- CustodyBreakMTTD <= 5 min (from event to IR ticket)
- EvidenceCompletenessRate_7d >= 99 percent
- LegalHoldGateAccuracy >= 99.9 percent

Outputs index [Informative]

[OC-1 DisposalCertificate], [OC-2 DisposalEvent], [OC-3 PolicyDispute], [OC-4 IRPolicyViolationEvent], [OC-5 CustodyHandoffReceipt], [OC-6 EvidenceBundle]

Technical Implementation Details (K4) [Informative]

Model and training profile [Informative]

model_id=secure-disposal-text; temperature=0.0; max_tokens_out=700
prompt_pack_id=disposal-v1 (800-88 rules, legal-hold gating, CoC rubric, evidence checklist)
RAG: sources={disposal policy, CMDB schema, ERP order schema, vendor list, evidence catalog}; max_docs=8; min_similarity=0.80; citations required
fine_tuning/adapters: none initially; eval on method-selection accuracy and gate correctness
guardrails: deny writes outside certificate/event scopes; strict evidence MIME allowlist

Memory and state [Informative]

working_memory.max_tokens=3k; eviction=recency_then_importance
episodic_memory: per mission_id journal (orders, assets, gates, evidence), ttl=365d
semantic_memory: namespaces=["800-88","custody","legal-hold","sites"];
embeddings=text-embedding-sec-v1; k=8
durable_state_store: event-sourced custody and certificate ledger; snapshot per order
consistency: exactly-once (OC-1 per asset); at-least-once (OC-2/OC-5/OC-6)
idempotency: per Output Contracts

Decision and routing logic [Informative]

Let:

- enc = encryption_at_rest (true|false)
- class = data_classification level (e.g., PII → high)
- media ∈ {HDD, SSD, Removable, Tape, Mobile, OT-PLC, ...}
- req = requested_method ∈ {clear, purge, destroy}
- cat = sanitization_category from CMDB ∈ {clear, purge, destroy}

Policy example:

- method_base(media, enc, class, cat) =
if legal_hold=true → block
else if media=SSD → purge (crypto_erase or sanitize)
else if media=HDD and class=high → destroy
else if media=HDD and enc=true → clear (crypto_erase acceptable)
else → cat (default)

- method = req if req is allowed_by_policy AND req >= method_base (order: clear < purge < destroy) else method_base

Gate rules:

- proceed only if legal_hold=false AND custody_chain_intact=true.
routing: on proceed → emit OC-2(status=in_progress → sanitized) → sign and emit OC-1 → OC-2(status=certified); on block → OC-2(status=blocked_legal_hold) and open dispute if filed.

Model Risk Management [Informative]

continuous_validation: daily (goldens for method selection, simulated holds, custody breaks)

thresholds: eval_pass_rate >= 99.5 percent → auto_HITL if below

red_team_cycle: monthly (fake witness, doctored photos, forged COI)

rollback_policy: eval_drop >= 1.5 pp for 48 h → revert model_id; notify owners

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

decision_rationale_template: who/what/why; method_basis; legal_hold check
timestamp; custody steps; evidence hashes

UI/API: expose classification_label, provenance.attestation, decision_rationale_url

audit_log_format: JSONL; retain per classification and legal_hold

Incident Response Integration [Informative]

Emit OC-4 on custody break/tamper; SOAR opens case and geofences assets.

Stakeholder Feedback Loop [Informative]

Emit OC-3 for disputes and OC-6 for evidence commentary; updates to prompt_pack only after governance review.

Data Sovereignty and Legal Hold [Informative]

Honor constraints.region at ingress/egress; legal_hold=true freezes purge and overrides retention.

Interfaces (links only) [Informative]

Consumes: ERP/Asset Mgmt; CMDB/Inventory; Legal Hold/eDiscovery

Produces: OC-1, OC-2, OC-3, OC-4, OC-5, OC-6

Safety and abuse prevention [Informative]

kill_switch on signature verification failure; geofence mismatch; duplicate certificate attempt; QPS limits per mission_id

Testing and validation [Informative]

contract tests for OC-1/OC-2; replay historical orders; custody-gap simulation; evidence integrity tests

Deployment and lifecycle [Informative]

Autoscale by queue depth; canary new evidence validators; SBOM + in-toto/SLSA attestations; sign all outputs

References / Standards [Informative]

NIST SP 800-88 Rev.1; NIST SP 800-53 Rev.5 (MP-6, MP-5, CM-8); NIST SP 800-161; NIST SP 800-160 Vol.2; NIST CSF 2.0; ISO/IEC 27040 (storage security); MITRE ATT&CK/D3FEND (asset disposal & data destruction)

MCP-Native Protocol Specification (K4) [Normative]

- **Native Protocol(s) Consumed:** Disposal Orders (ERP/Asset Mgmt); Asset Inventory (CMDB/Inventory); Legal Hold/eDiscovery.
- **Native Protocol(s) Produced:** DisposalCertificate (REST/gRPC); DisposalEvent (Kafka/AMQP); optional CustodyHandoffReceipt; EvidenceBundle.
- **MCP Context Fields:**
 - **Required:** mission_id; role="SecureDisposalAgent"; intent="dispose"; provenance (SPIFFE ID, signing KID, attestation); policy_refs
 - **Optional:** constraints; classification; decision_basis; legal_hold
- **Enforcement Note:** Execution systems MUST verify legal_hold state and chain-of-custody before any sanitize/destroy, and validate certificate signature/provenance prior to closure.
- **Versioning and compatibility; producers/consumers registry:** authoritative here; see Schema Capsules for acceptance ranges/EOL.
- **Example payloads:** native and MCP-wrapped examples above (authoritative).
- **Transparency hooks:** classification_label, provenance.attestation, decision_rationale_url available to downstream UIs/APIs.

Conformance: This section is **[Normative]** and, together with each **Schema Capsule**, defines testable requirements.

